

Superficie de Ataque en Correos Corporativos

Exposición y Remediación de Credenciales

AIACO Corp — Dominio aiaco.local · Attack Surface Management (ASM)

ESTUDIANTE / PRACTICANTE

Jesús Alejandro Rodríguez Medina

ORGANIZACIÓN / PROYECTO

AIACO Corp

PROYECTO MARCO

Attack Surface Management (ASM)

ROL

DevSecOps / Analista de Ciberseguridad Jr.

VECTOR EVALUADO

Correos Corporativos y Credenciales

ENTORNO

Windows 10 Pro + WSL2 + Docker

OWASP ASVS — Gestión de Credenciales

CIS Control 5 — Cuentas

ISO/IEC 27001 · A.9

1. Ficha General del Documento

Campo	Detalle Corporativo / Académico
Estudiante / Practicante	Jesús Alejandro Rodríguez Medina
Rol	DevSecOps / Analista de Ciberseguridad Jr.
Organización / Proyecto	AIACO Corp
Proyecto Marco	Attack Surface Management (ASM)
Vector Evaluado	Correos Corporativos y Credenciales (Email Security)
Estado del Laboratorio	COMPLETADO

2. Objetivo del Laboratorio

Identificar exposición de credenciales corporativas almacenadas de forma insegura, evaluar el riesgo asociado, ejecutar una remediación simulada sobre el hallazgo principal y validar técnicamente que la corrección se aplicó sin pérdida de integridad de los datos.

RIESGO INICIAL CRÍTICO	CREDENCIALES EN TEXTO PLANO 3	USUARIOS SOLO CON HASH MD5 2	TEXTO PLANO POST- REMEDIACIÓN 0
----------------------------------	--	---	--

3. Herramientas y Entorno

Elemento	Detalle
Sistema Operativo	Windows 10 Pro (PowerShell como consola principal)
Subsistema Linux	WSL2 — Ubuntu (verificado con <code>wsl -l -v</code>)
Contenedores	Docker Desktop, Docker Engine, Docker Compose
Base de Datos	MySQL 8.0 (ejecutándose dentro de Docker)
Editor Utilizado	Visual Studio Code

Estructura del Laboratorio

```
emailscorp/  
|
```

```
├─ docker-compose.yml
├─ aiaco_corporate_emails.csv
├─ case1.md
├─ mysql/
│   └─ init.sql
```

Base de Datos Simulada

Base de datos **aiaco**, tabla **leaked_credentials**.

Alcance Declarado

Durante este laboratorio **no** se utilizaron herramientas OSINT externas (Hunter.io, MXToolbox, SecurityTrails, HavelBeenPwned, theHarvester). Esas herramientas corresponden a una fase distinta del proyecto ASM y quedan fuera del alcance de este ejercicio.

4. Comandos y Pasos Técnicos Ejecutados

4.1. Verificación y Despliegue del Entorno Docker

```
docker version
docker ps
```

Objetivo: comprobar que Docker Engine estuviera activo y revisar contenedores en ejecución. Resultado: contenedor **aiaco_mysql** activo.

```
docker compose up -d
```

Objetivo: crear el contenedor MySQL, montar el volumen y ejecutar automáticamente **mysql/init.sql**.

```
docker logs aiaco_mysql
```

Objetivo: verificar que MySQL iniciara correctamente, que se creara la base de datos y se ejecutara el script de inicialización.

4.2. Exploración de la Base de Datos

```
docker exec -it aiaco_mysql mysql -u root -p
SHOW DATABASES;
USE aiaco;
SHOW TABLES;
SELECT * FROM leaked_credentials;
```

Resultado: tabla **leaked_credentials** con cinco usuarios — tres contraseñas en texto plano y dos hashes MD5.

4.3. Identificación de Credenciales Vulnerables

```
SELECT email, password_plain
FROM leaked_credentials
WHERE password_plain IS NOT NULL;
```

Resultado: **3 usuarios** con credenciales expuestas en texto plano.

```
SELECT email, password_plain
FROM leaked_credentials
WHERE password_plain IN ('password', '123456', 'admin', 'qwerty');
```

Resultado: se detectaron **2 contraseñas extremadamente débiles** ("password" y "123456").

```
SELECT email, password_md5
FROM leaked_credentials
WHERE password_plain IS NULL;
```

Resultado: **2 usuarios** almacenaban únicamente un hash MD5.

4.4. Estadísticas, Clasificación y Priorización de Riesgo

```
SELECT COUNT(*) AS usuarios_texto_plano FROM leaked_credentials WHERE password_plain IS NOT NULL;
SELECT COUNT(*) AS usuarios_hash FROM leaked_credentials WHERE password_plain IS NULL;

SELECT email,
       CASE WHEN password_plain IS NOT NULL THEN 'CRITICO' ELSE 'MEDIO' END AS nivel_riesgo
FROM leaked_credentials;

SELECT COUNT(*) AS total_usuarios,
       SUM(password_plain IS NOT NULL) AS texto_plano,
       SUM(password_plain IS NULL) AS solo_hash
FROM leaked_credentials;
```

Se clasificó cada registro por nivel de riesgo (CRÍTICO / MEDIO) y se generó un conteo general de exposición.

4.5. Análisis de Dominio

```
SELECT DISTINCT SUBSTRING_INDEX(email, '@', -1) AS dominio FROM leaked_credentials;

SELECT SUBSTRING_INDEX(email, '@', -1) AS dominio, COUNT(*)
FROM leaked_credentials GROUP BY dominio;
```

Resultado: los cinco usuarios pertenecían a un único dominio corporativo, **aiaco.local**.

4.6. Remediación Simulada

```
-- Respaldo previo a la corrección
CREATE TABLE leaked_credentials_backup AS
SELECT * FROM leaked_credentials;

-- Eliminación del texto plano expuesto
UPDATE leaked_credentials_backup
SET password_plain = NULL
WHERE password_plain IS NOT NULL;
```

Objetivo: eliminar únicamente la información sensible, sin eliminar usuarios ni modificar los hashes existentes, preservando la tabla original como evidencia.

```
SELECT * FROM leaked_credentials_backup WHERE password_plain IS NOT NULL;
-- Resultado: Empty Set

SELECT COUNT(*) FROM leaked_credentials_backup;
-- Resultado: 5
```

Validación: cero contraseñas en texto plano tras la remediación; los cinco registros se conservaron intactos.

5. Resultados y Hallazgos Obtenidos

5.1. Formato de Correo Identificado

Todos los usuarios seguían el formato **nombre.apellido@aiaco.local**:

alejandro.rodriguez@aiaco.local

laura.garcia@aiaco.local

miguel.lopez@aiaco.local

fernanda.silva@aiaco.local

juan.torres@aiaco.local

5.2. Elementos No Evaluados en este Laboratorio

Fuera de alcance en este ejercicio: registros **SPF**, **DKIM**, **DMARC** y **MX**, así como enumeración DNS y herramientas OSINT externas.

5.3. Estado de Credenciales por Usuario

Usuario	Estado
alejandro.rodriguez@aiaco.local	Hash MD5
laura.garcia@aiaco.local	Texto plano (antes de la remediación)
miguel.lopez@aiaco.local	Texto plano (antes de la remediación)
fernanda.silva@aiaco.local	Hash MD5
juan.torres@aiaco.local	Texto plano (antes de la remediación)

5.4. Hallazgos Principales

Hallazgo 1 — Credenciales en texto plano

Crítica

Tres credenciales corporativas almacenadas sin ningún tipo de cifrado ni hashing.

Hallazgo 2 — Hashing débil (MD5)

Media

Dos usuarios utilizaban únicamente hash MD5, algoritmo considerado criptográficamente roto y vulnerable a ataques de fuerza bruta / rainbow tables.

Hallazgo 3 — Contraseñas extremadamente débiles

Crítica

Se identificaron las contraseñas "password" y "123456" entre las credenciales expuestas.

Hallazgo 4 — Concentración de dominio

Media

Todos los usuarios pertenecían al mismo dominio corporativo (aiaco.local), lo que facilita ataques dirigidos de phishing o password spraying contra toda la organización.

6. Remediación y Validación

Se creó un respaldo de la tabla original (**leaked_credentials_backup**) y se eliminaron los valores de la columna **password_plain** mediante una actualización SQL controlada, conservando los registros de usuario y los hashes existentes como evidencia de auditoría.

ANTES DE LA REMEDIACIÓN

- Riesgo general: Crítico
- 3 contraseñas en texto plano
- Posible compromiso inmediato de cuentas
- Alto riesgo de movimiento lateral y escalamiento de privilegios

DESPUÉS DE LA REMEDIACIÓN

- 0 contraseñas en texto plano
- 5 usuarios conservados (0 eliminados)
- Integridad de la tabla conservada
- Persisten hashes MD5 pendientes de migrar

Métrica de Validación	Resultado
Total de usuarios	5
Contraseñas en texto plano	0
Usuarios eliminados	0
Integridad de la tabla	Conservada

7. Plan de Mitigación y Recomendaciones (Blue Team)

- 1 **Migrar los hashes MD5 a algoritmos modernos:** Argon2, bcrypt o scrypt, con salting individual por usuario, para eliminar la debilidad criptográfica residual.
- 2 **Reforzar las políticas de contraseñas:** longitud mínima, complejidad y bloqueo de contraseñas comunes (deny-list) para evitar valores como "password" o "123456".
- 3 **Eliminar el almacenamiento de contraseñas en texto plano** de cualquier sistema productivo; nunca debe existir una columna equivalente a *password_plain* fuera de un entorno de laboratorio controlado.
- 4 **Evaluar la exposición a nivel de dominio:** dado que todos los usuarios comparten aiaco.local, se recomienda una fase posterior de revisión OSINT (SPF, DKIM, DMARC, MX) y simulacros de phishing dirigido.

- 5 **Implementar autenticación multifactor (MFA)** para todas las cuentas del dominio corporativo como controles compensatorios ante una eventual fuga de credenciales.

8. Aprobación y Conformidad

El presente reporte certifica el cumplimiento exitoso del laboratorio de superficie de ataque en correos corporativos, dentro del programa de Prácticas Profesionales en Ciberseguridad del proyecto ASM para AIACO Corp.

Jesús Alejandro Rodríguez Medina

Practicante de Ciberseguridad / DevSecOps
AIACO Corp

✓ **LABORATORIO COMPLETADO**